

BAPPA UTSAV 2026

Comprehensive Codebase Technical Audit Report (Anti-Fabrication & Empirical Verification)

AUDIT TARGET	LAUNCH TIMESTAMP	DATABASE ENGINE	AUDIT STATUS
Bappa Utsav 2026	14 Sep 2026, 5:00 PM IST	Google Cloud Firestore	Completed / Verified

1. Executive Summary & Verdict Matrix

#	Audit Dimension	Target Files & Lines	Audit Verdict	Core Finding
1	Vote Deduplication	<code>votingService.js:190-232</code> <code>api/vote.ts:183-231</code>	VERIFIED	Ballot existence check occurs inside the atomic transaction. Zero race condition window.
2	Failure Fallback Paths	<code>votingService.js:247-413</code>	VERIFIED	All error, network, and status $\neq$ 200 paths return <code>success: false</code> without caching unpersisted votes.
3	Security Rules: Write Scope	<code>firestore.rules:15-44</code>	VULNERABILITY	Unconstrained shard writes allow arbitrary count injection (+999999). Catch-all rule permits open writes.
4	Security Rules: Read Scope	<code>firestore.rules:41-44</code>	PRIVACY LEAK	Catch-all <code>match /{document=**} { allow read: if true; }</code> overrides ballot privacy.
5	Firebase App Check	<code>firebase.ts:96-109</code> <code>api/vote.ts:57-78</code>	PARTIAL	Initialized client-side; not enforced in <code>firestore.rules</code> . Backend enforcement conditional on env.
6	Launch Time Gating	<code>LaunchGate.jsx:8-10</code> <code>api/vote.ts</code>	FRONTEND ONLY	Frontend UI gated properly, but <code>api/vote.ts</code> and <code>firestore.rules</code> lack server timestamp rejection.
7	Read / Quota Concurrency	<code>api/counters.ts:37</code> <code>useLiveVotes.js:5-38</code>	PARTIAL	Edge CDN cache (s-maxage=20) protects backend. However, concurrent cold serverless instances query 210 shards each.
8	Identity & Sybil Resistance	<code>AuthContext.jsx:54-88</code> <code>api/vote.ts:163</code>	VERIFIED	Strict 1:1 binding to Google Account UID. Sybil threshold relies on Google account creation friction.
9	Asset & Bundle Loading	<code>vite.config.js:136</code> <code>PandhalCard.jsx:49</code>	PARTIAL	Images use native lazy loading. JavaScript bundle lacks route code-splitting for Coming Soon page.
10	Monitoring Infrastructure	Codebase Config	NOT CONFIGURED	No alerting config in repo files. Free UptimeRobot &

#	Audit Dimension	Target Files & Lines	Audit Verdict	Core Finding
				GCP app setup recommended.

2. Detailed Line-by-Line Itemized Audit

Item 1: Vote Deduplication & Transaction Atomicity

VERIFIED

Code Evidence: [`src/services/votingService.js:190–232`](file:///d:/Ganesh-Website/src/services/votingService.js#L190–L232) & [`api/vote.ts:183–231`](file:///d:/Ganesh-Website/api/vote.ts#L183–L231)

- `votingService.js` Line 190 opens `runTransaction(db, async (transaction) => {`.
- Line 191 executes `const voterSnap = await transaction.get(voterDocRef);` reading document `/voters/ganapathi_chaturthi_2026_${uid}`.
- Lines 192–206 evaluate `if (voterSnap.exists())`. If the ballot exists, it returns `ALREADY_VOTED` or `IDEMPOTENT_SUCCESS`.
- Lines 208–225 write the voter ballot and increment the shard **only** when `voterSnap.exists()` is false.

Adversarial Trace: If two requests for the same UID execute simultaneously in parallel tabs, the first to commit locks the document version. The second transaction's read version becomes stale; Firestore automatically aborts and retries the transaction from the top, reading the newly committed ballot and exiting with zero shard increments.

Item 2: Fallback Paths on Failure

VERIFIED

Code Evidence: [`src/services/votingService.js:247–413`](file:///d:/Ganesh-Website/src/services/votingService.js#L247–L413)

- **Lines 250–256:** Missing Google UID returns `{ success: false, errorType: 'INVALID_ACCOUNT' }`.
- **Lines 258–264:** Unrecognized pandhal ID returns `{ success: false, errorType: 'INVALID_PANDHAL' }`.
- **Lines 362–377:** HTTP 409 Conflict returns `{ success: false, errorType: 'ALREADY_VOTED' }`.
- **Lines 379–385:** HTTP 429 Rate Limit returns `{ success: false, errorType: 'RATE_LIMIT_EXCEEDED' }`.
- **Lines 387–393:** HTTP 401 Unauthorized returns `{ success: false, errorType: 'INVALID_TOKEN' }`.
- **Lines 396–402:** Unexpected HTTP response ($\neq$ 200/409/429/401) returns `{ success: false, errorType: 'SERVER_ERROR' }`.
- **Lines 403–412:** Fetch network exception returns `{ success: false, errorType: 'NETWORK_ERROR' }`.

None of the failure branches call `setMyVote()` or increment `countsCache`.

Item 3: Firestore Security Rules — Write Scope

VULNERABILITY FOUND

Code Evidence: [`firestore.rules:15–28, 41–44`](file:///d:/Ganesh-Website/firestore.rules#L15–L28)

Vulnerability 1 (Arbitrary Shard Write): Lines 20–28 define `match /counters/{pandhalId}/shards/{shardId} { allow write: if request.auth != null; }`. It does not enforce `count == resource.data.count + 1`. An authenticated attacker can invoke `setDoc(doc(db, 'counters/pandhal-01/shards/shard_0'), { count: 999999 })` directly from browser DevTools.

Vulnerability 2 (Catch-All Override): Lines 41–44 define `match /{document=**} { allow write: if request.auth != null; }`. In Firestore Security Rules, matches are combined with a logical **OR**, opening write access across every collection.

Item 4: Firestore Security Rules — Read Scope & Privacy

PRIVACY LEAK

Code Evidence: [`firestore.rules:31–34, 41–44`](file:///d:/Ganesh-Website/firestore.rules#L31–L44)

- Line 33 intends to restrict voter ballot reads: `allow read: if request.auth != null && voterDocId == ('ganapathi_chaturthi_2026_' + request.auth.uid);`.
- However, Line 42 catch-all rule `match /{document=**} { allow read: if true; }` overrides the subpath rule, allowing unauthenticated users to enumerate and query the entire `/voters` collection.

Item 5: Firebase App Check Enforcement

PARTIALLY ENFORCED

Code Evidence: [`src/lib/firebase.ts:96–109`](file:///d:/Ganesh-Website/src/lib/firebase.ts#L96–L109) & [`api/vote.ts:57–78`](file:///d:/Ganesh-Website/api/vote.ts#L57–L78)

- App Check is initialized in client bundle using `ReCaptchaV3Provider`.
- `firestore.rules` contains no `request.appCheck != null` verification.
- `api/vote.ts` Line 57 checks `process.env.APP_CHECK_ENFORCED === 'true'`. Without this environment variable set in production, token verification only logs a warning.
- Debug Token Status:** Clean. Zero debug tokens are present in source code.

Item 6: Launch Time Gating

FRONTEND ONLY

Code Evidence: [`src/components/launch/LaunchGate.jsx:8–10`](file:///d:/Ganesh-Website/src/components/launch/LaunchGate.jsx#L8–L10) & [`api/vote.ts`](file:///d:/Ganesh-Website/api/vote.ts)

- Frontend `LaunchGate.jsx` gates the UI before `1789385400000` (14 Sep 2026, 5:00 PM IST) and syncs server `Date` headers to mitigate local clock drift.
- However, `api/vote.ts` and `firestore.rules` contain **no server-side timestamp validation**. An attacker sending direct HTTP POST requests to `/api/vote` before 5:00 PM will have their vote recorded.

Item 7: Read / Quota Concurrency Math

PARTIALLY VERIFIED

Code Evidence: [`api/counters.ts:13-84`](file:///d:/Ganesh-Website/api/counters.ts#L13-L84) & [`src/hooks/useLiveVotes.js:5-38`](file:///d:/Ganesh-Website/src/hooks/useLiveVotes.js#L5-L38)

Concurrent Users (N)	Voting Rate (V)	Raw onSnapshot Reads/Min	Edge Cached Reads/Min	Spark 50K Quota Survival
100 users	2 votes/sec	12,120 / min	~603 / min	4.1 min (Raw) vs > 24h (Edge)
500 users	5 votes/sec	150,300 / min	~603 / min	20 sec (Raw) vs > 24h (Edge)
1,000 users	10 votes/sec	600,600 / min	~603 / min	5 sec (Raw) vs > 24h (Edge)

Cold Start Note: In-instance micro-cache is container-isolated. If 20 cold container instances spin up simultaneously, each executes `collectionGroup('shards').get()` (generating 4,200 reads during cold burst).

Item 8: Identity & Sybil Resistance

VERIFIED

Code Evidence: [``src/context/AuthContext.jsx:54-88``](file:///d:/Ganesh-Website/src/context/AuthContext.jsx#L54-L88) & [``api/vote.ts:163``](file:///d:/Ganesh-Website/api/vote.ts#L163)

- Auth relies on Google OAuth ID tokens. Document ID is bound to `ganapathi_chaturthi_2026_${uid}`.
- One Google account can cast exactly 1 vote.
- Nothing prevents a user with multiple Google accounts from voting multiple times. Sybil friction is bounded by Google's account creation verification.

Item 9: Asset & Bundle Loading

PARTIALLY VERIFIED

Code Evidence: [``src/components/pandhal/PandhalCard.jsx:49``](file:///d:/Ganesh-Website/src/components/pandhal/PandhalCard.jsx#L49) & [``vite.config.js:136-140``](file:///d:/Ganesh-Website/vite.config.js#L136-L140)

- Pandhal cards load cover thumbnails using `loading="lazy"`.
- 4K multi-photo galleries in `PandhalGallery.jsx` are mounted into the DOM only when the modal is opened.
- JavaScript bundle is 689 kB (175 kB gzipped). Code-splitting for the Coming Soon gate is not configured in `vite.config.js`.

Item 10: Monitoring Infrastructure

NOT CONFIGURED

No monitoring or alerting configuration files are committed in the repository. Recommendations provided for free UptimeRobot pings and GCP Console mobile app.

3. Mandatory Hardened Ruleset (Remediation for Items 3 & 4)

```
rules_version = '2';

service cloud.firestore {
  match /databases/{database}/documents {

    // 1. Sharded Counters (Strict +1 increments only)
    match /counters/{pandhalId} {
      allow read: if true;
      allow write: if false;
    }

    match /counters/{pandhalId}/shards/{shardId} {
      allow read: if true;
      allow create: if request.auth != null && request.resource.data.count == 1;
      allow update: if request.auth != null
        && request.resource.data.count == (resource.data.count + 1);
      allow delete: if false;
    }

    match /[path=**]/shards/{shardId} {
      allow read: if true;
      allow create: if request.auth != null && request.resource.data.count == 1;
      allow update: if request.auth != null
        && request.resource.data.count == (resource.data.count + 1);
      allow delete: if false;
    }

    // 2. Voter Ballots (Strict 1:1 ballot immutability & privacy)
    match /voters/{voterDocId} {
      allow read: if request.auth != null
        && voterDocId == ('ganapathi_chaturthi_2026_' + request.auth.uid);

      allow create: if request.auth != null
        && voterDocId == ('ganapathi_chaturthi_2026_' + request.auth.uid)
        && request.resource.data.uid == request.auth.uid
        && request.resource.data.eventId == 'ganapathi_chaturthi_2026'
        && request.time >= timestamp.date(2026, 9, 14);

      allow update, delete: if false;
    }

    // 3. Strict Closed Fallback
    match /[document=**] {
      allow read, write: if false;
    }
  }
}
```

4. STILL UNVERIFIED

The following items could not be fully verified from local repository files alone:

1. **Firestore Console App Check Enforcement:** Cannot verify whether "Enforcement" toggle is enabled in Firestore Console (App Check > Firestore). *Needed:* Firestore Console verification or `firebase.json` configuration.
2. **Production Environment Secrets:** Cannot verify active runtime values of `APP_CHECK_ENFORCED` and `FIREBASE_SERVICE_ACCOUNT_KEY` in Vercel. *Needed:* Vercel project environment configuration dump.